

Computer Security

Cryptography

Secure Communication

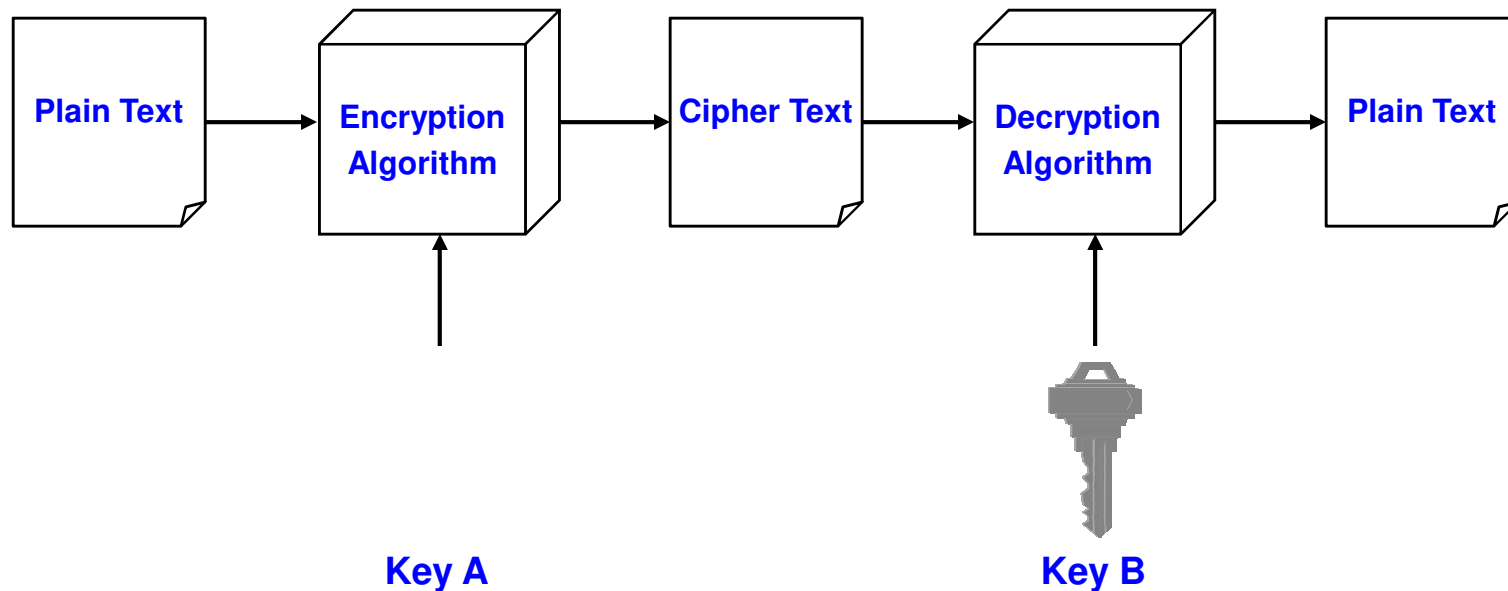
- Well established needs for secure communication
 - War time communication
 - Business transactions
 - Illicit Love Affairs
- Requirements of secure communication
 1. Secrecy
 - Only intended receiver understands the message
 2. Authentication
 - Sender and receiver need to confirm each others identity
 3. Message Integrity
 - Ensure that their communication has not been altered, either maliciously or by accident during transmission

Cryptography

- Cryptography is the science of secret, or hidden writing
- It has two main Components:
 1. Encryption
 - Practice of hiding messages so that they can not be read by anyone other than the intended recipient
 2. Authentication
 - Ensuring that users of data/resources are the persons they claim to be and that a message has not been surreptitiously altered

Encryption - Cipher

- Cipher is a method for encrypting messages



- Encryption algorithms are standardized & published
- The key which is an input to the algorithm is secret
 - Key is a string of numbers or characters
 - If same key is used for encryption & decryption the algorithm is called symmetric
 - If different keys are used for encryption & decryption the algorithm is called asymmetric

Encryption - Symmetric Algorithms

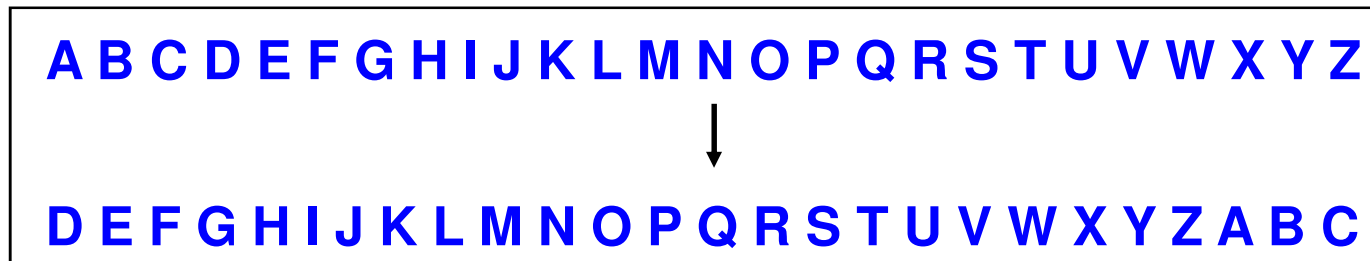
- Algorithms in which the key for encryption and decryption are the same are Symmetric
 - Example: Caesar Cipher
- Types:
 1. Block Ciphers
 - Encrypt data one block at a time (typically 64 bits, or 128 bits)
 - Used for a single message
 2. Stream Ciphers
 - Encrypt data one bit or one byte at a time
 - Used if data is a constant stream of information

Symmetric Encryption – Key Strength

- Strength of algorithm is determined by the size of the key
 - The longer the key the more difficult it is to crack
- Key length is expressed in bits
 - Typical key sizes vary between 48bits and 448 bits
- Set of possible keys for a cipher is called key space
 - For 40-bit key there are 2^{40} possible keys
 - For 128-bit key there are 2^{128} possible keys
 - Each additional bit added to the key length doubles the security
- To crack the key the hacker has to use brute-force
 - (i.e. try all the possible keys till a key that works is found)
 - Super Computer can crack a 56-bit key in 24 hours
 - It will take 2^{72} times longer to crack a 128-bit key
(Longer than the age of the universe)

Symmetric Algorithms – Caesar Cipher

- Caesar Cipher is a method in which each letter in the alphabet is rotated by three letters as shown

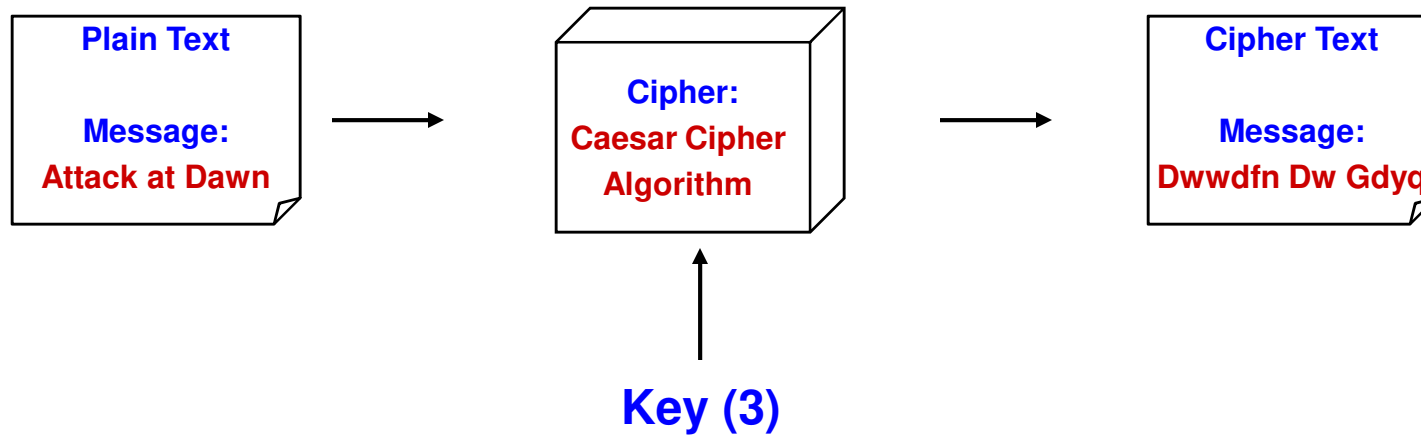


- Let us try to encrypt the message
 - Attack at Dawn

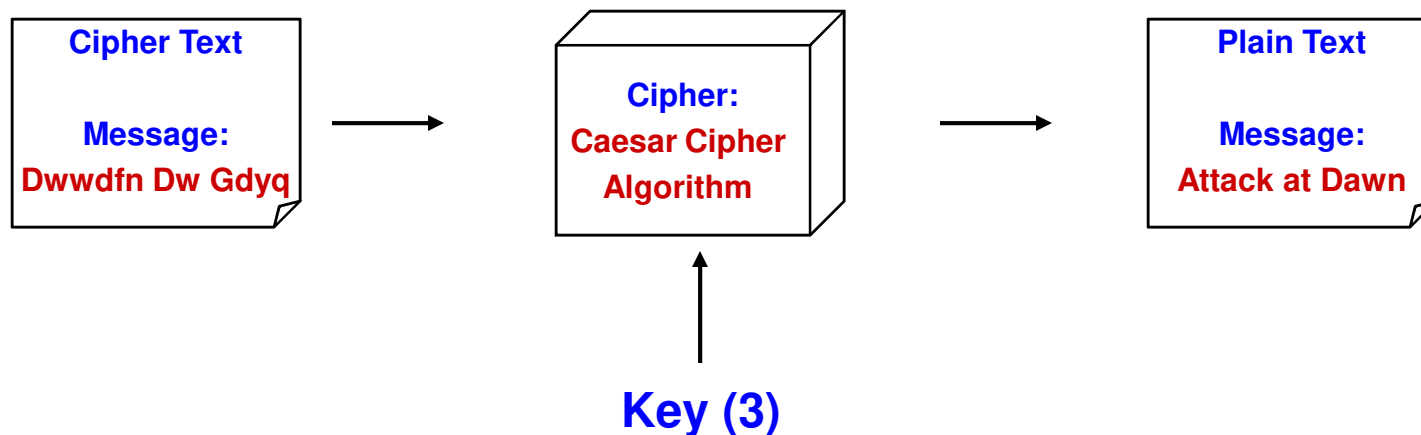
Assignment: Each student will exchange a secret message with his/her closest neighbor about some other person in the class and the neighbor will decipher it.

Symmetric Algorithms - Caesar Cipher

Encryption



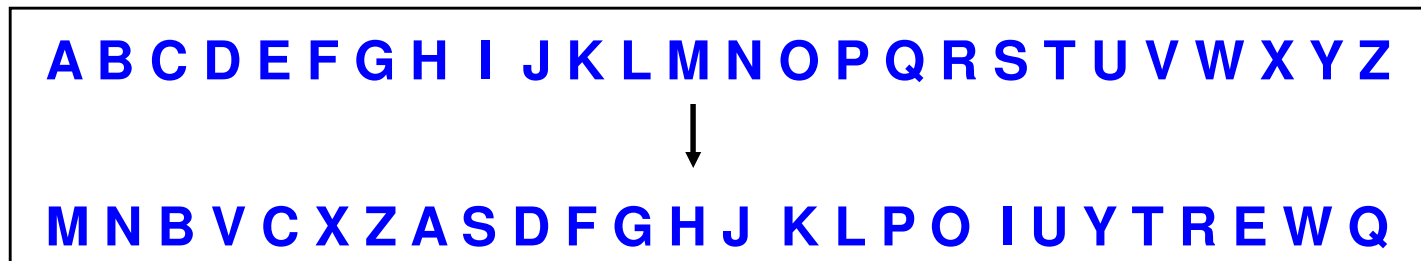
Decryption



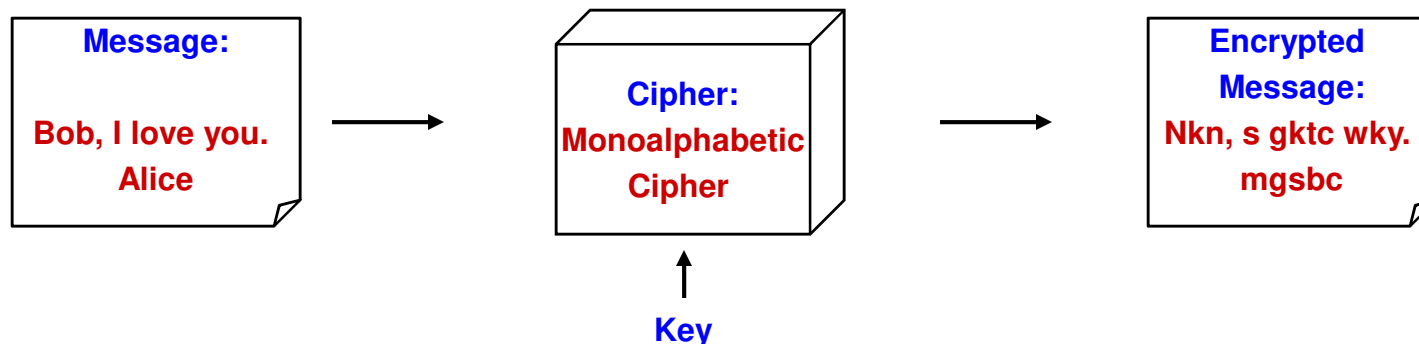
How many different keys are possible?

Symmetric Algorithms - Monoalphabetic Cipher

- Any letter can be substituted for any other letter
 - Each letter has to have a unique substitute



- There are $26!$ pairing of letters ($\sim 10^{26}$)
- Brute Force approach would be too time consuming
 - Statistical Analysis would make it feasible to crack the key

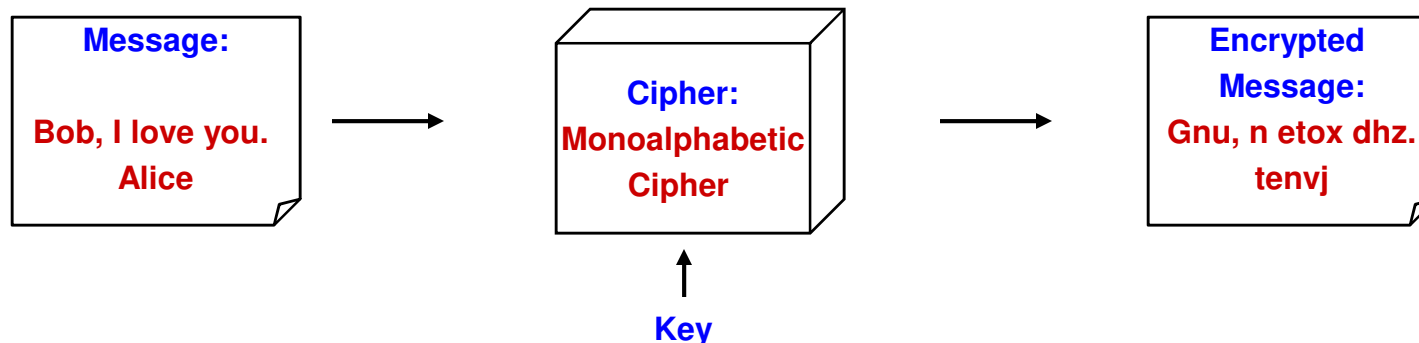


Symmetric Algorithms - Polyalphabetic Cipher

- Developed by Blaise de Vigenere
 - Also called Vigenere cipher
- Uses a sequence of monoalphabetic ciphers in tandem
 - e.g. C_1, C_2, C_2, C_1, C_2

Plain Text	A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
	↓
C1(k=6)	F G H I J K L M N O P Q R S T U V W X Y Z A B C D E
C1(k=20)	T U V W X Y Z A B C D E F G H I J K L M N O P Q R S

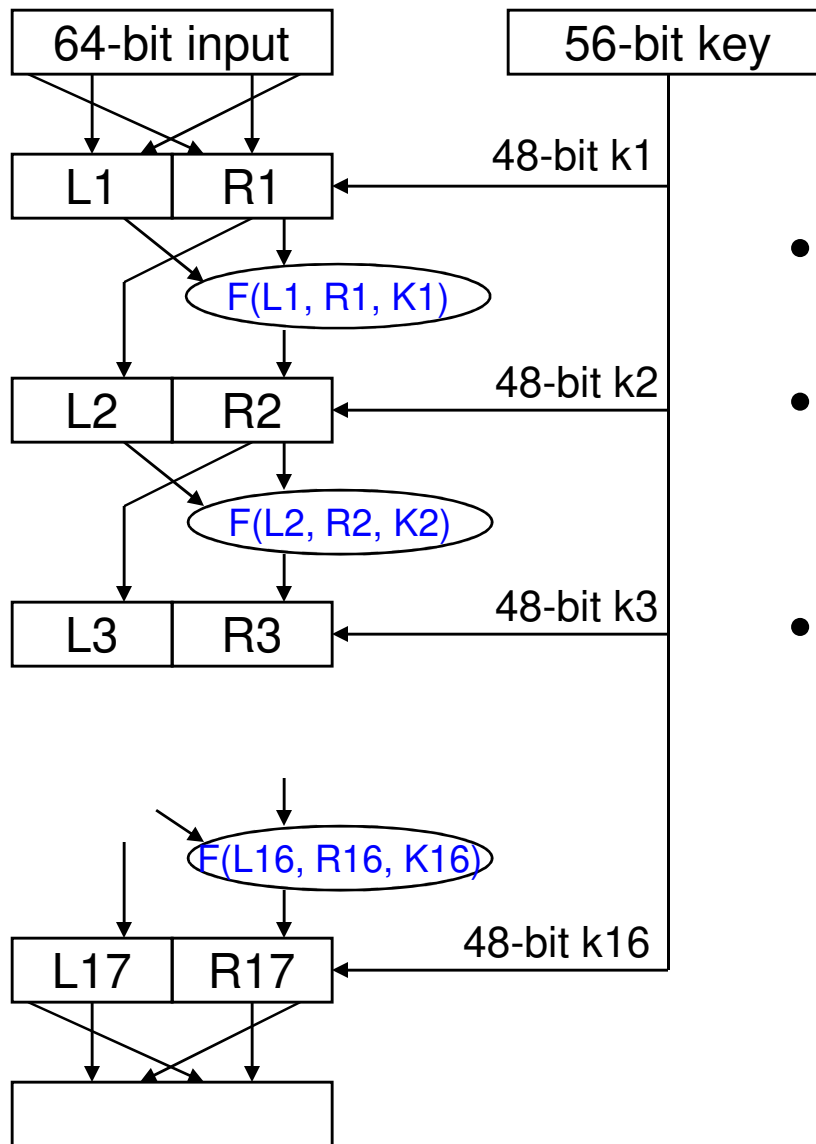
- Example



Data Encryption Standard (DES)

- Goal of DES is to completely scramble the data and key so that every bit of cipher text depends on every bit of data and every bit of key
- DES is a block Cipher Algorithm
 - Encodes plaintext in 64 bit chunks
 - One parity bit for each of the 8 bytes thus it reduces to 56 bits
- It is the most used algorithm
 - Standard approved by US National Bureau of Standards for Commercial and nonclassified US government use in 1993

Data Encryption Standard (DES)



- DES run in reverse to decrypt
- Cracking DES
 - 1997: 140 days
 - 1999: 14 hours
- TripleDES uses DES 3 times in tandem
 - Output from 1 DES is input to next DES

Summary of Encryption Algorithm

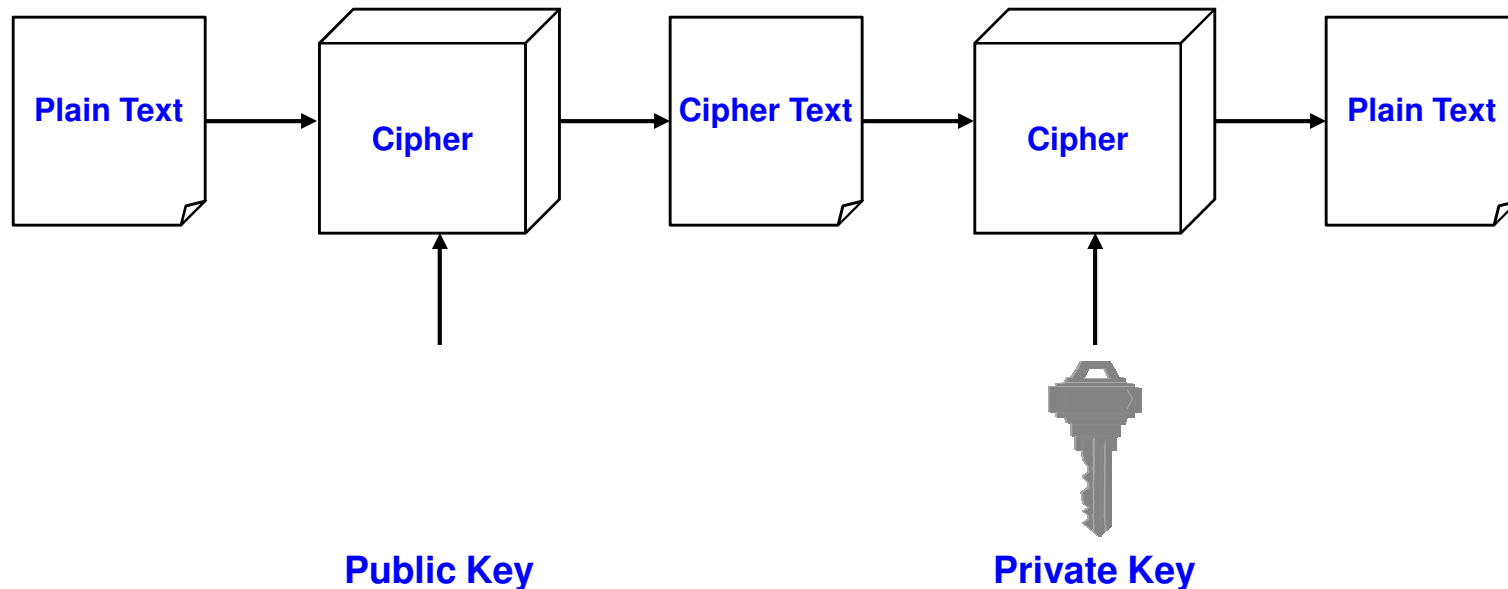
Algorithm	Type	Key Size	Features
DES	Block Cipher	56 bits	Most Common, Not strong enough
TripleDES	Block Cipher	168 bits (112 effective)	Modification of DES, Adequate Security
Blowfish	Block Cipher	Variable (Up to 448 bits)	Excellent Security
AES	Block Cipher	Variable (128, 192, or 256 bits)	Replacement for DES, Excellent Security
RC4	Stream Cipher	Variable (40 or 128 bits)	Fast Stream Cipher, Used in most SSL implementations

Symmetric Encryption – Limitations

- Any exposure to the secret key compromises secrecy of ciphertext
- A key needs to be delivered to the recipient of the coded message for it to be deciphered
 - Potential for eavesdropping attack during transmission of key

Asymmetric Encryption

- Uses a pair of keys for encryption
 - Public key for encryption
 - Private key for decryption
- Messages encoded using public key can only be decoded by the private key
 - Secret transmission of key for decryption is not required
 - Every entity can generate a key pair and release its public key



Asymmetric Encryption

- Two most popular algorithms are RSA & El Gamal
 - RSA
 - Developed by Ron Rivest, Adi Shamir, Len Adelman
 - Both public and private key are interchangeable
 - Variable Key Size (512, 1024, or 2048 bits)
 - Most popular public key algorithm
 - El Gamal
 - Developed by Taher ElGamal
 - Variable key size (512 or 1024 bits)
 - Less common than RSA, used in protocols like PGP

Asymmetric Encryption - RSA

- Choose two large prime numbers p & q
- Compute $n=pq$ and $z=(p-1)(q-1)$
- Choose number e , less than n , which has no common factor (other than 1) with z
- Find number d , such that $ed - 1$ is exactly divisible by z Keys are generated using n , d , e
 - Public key is (n,e)
 - Private key is (n, d)
- Encryption: $c = m^e \bmod n$
 - m is plain text
 - c is cipher text
- Decryption: $m = c^d \bmod n$
- Public key is shared and the private key is hidden

Asymmetric Encryption - RSA

- $P=5$ & $q=7$
- $n=5*7=35$ and $z=(4)*(6) = 24$
- $e = 5$
- $d = 29$, $(29 \times 5 - 1)$ is exactly divisible by 24
- Keys generated are
 - Public key: $(35, 5)$
 - Private key is $(35, 29)$
- Encrypt the word love using $(c = m^e \bmod n)$
 - Assume that the alphabets are between 1 & 26

Plain Text	Numeric Representation	m^e	Cipher Text ($c = m^e \bmod n$)
l	12	248832	17
o	15	759375	15
v	22	5153632	22
e	5	3125	10

Asymmetric Encryption - RSA

- Decrypt the word love using ($m = c^d \bmod n$)
 - $n = 35, c=29$

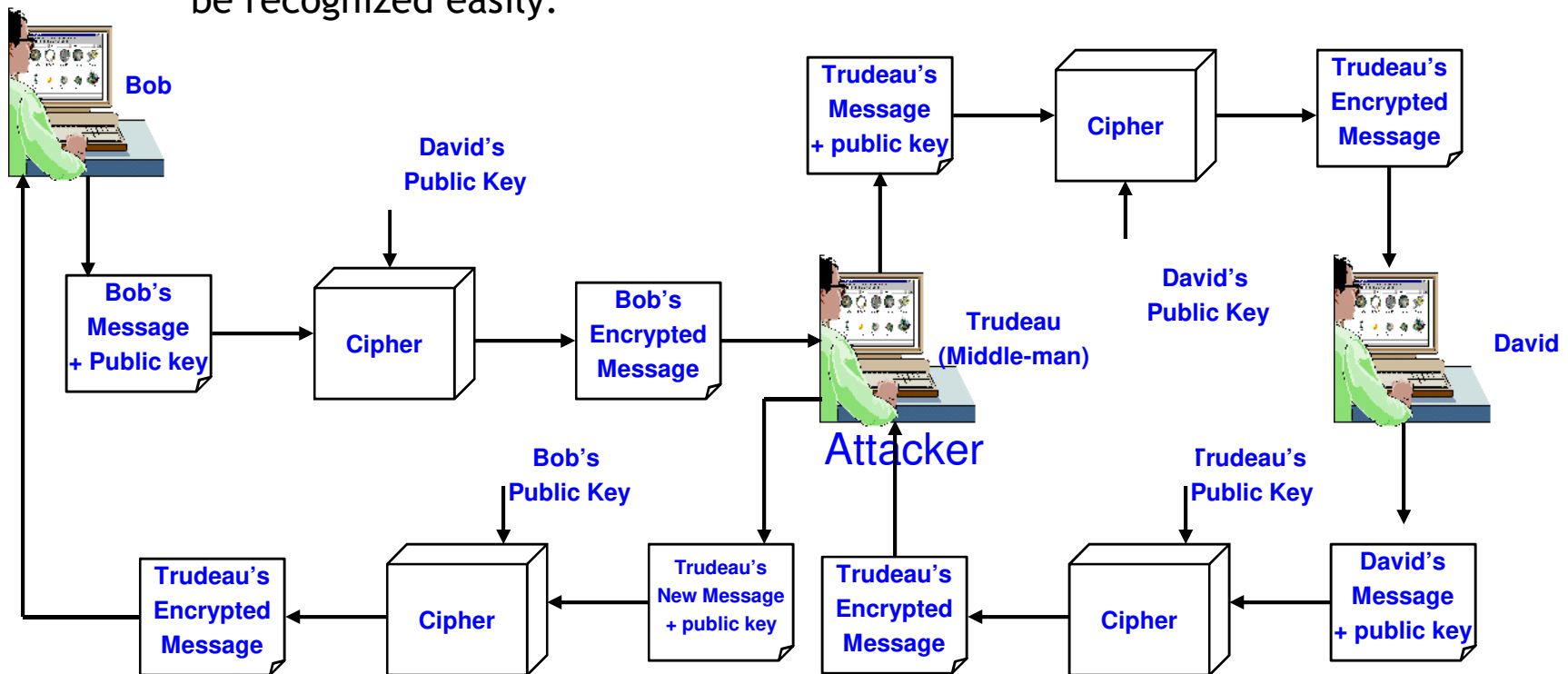
Cipher Text	c^d	$(m = m^e \bmod n)$	Plain Text
17	481968572106750915091411825223072000	17	l
15	12783403948858939111232757568359400	15	o
22	852643319086537701956194499721110000000	22	v
10	10000000000000000000000000000000	10	e

Asymmetric Encryption - Weaknesses

- Efficiency is lower than Symmetric Algorithms
 - A 1024-bit asymmetric key is equivalent to 128-bit symmetric key
- Potential for eavesdropping attack during transmission of key
- It is problematic to get the key pair generated for the encryption

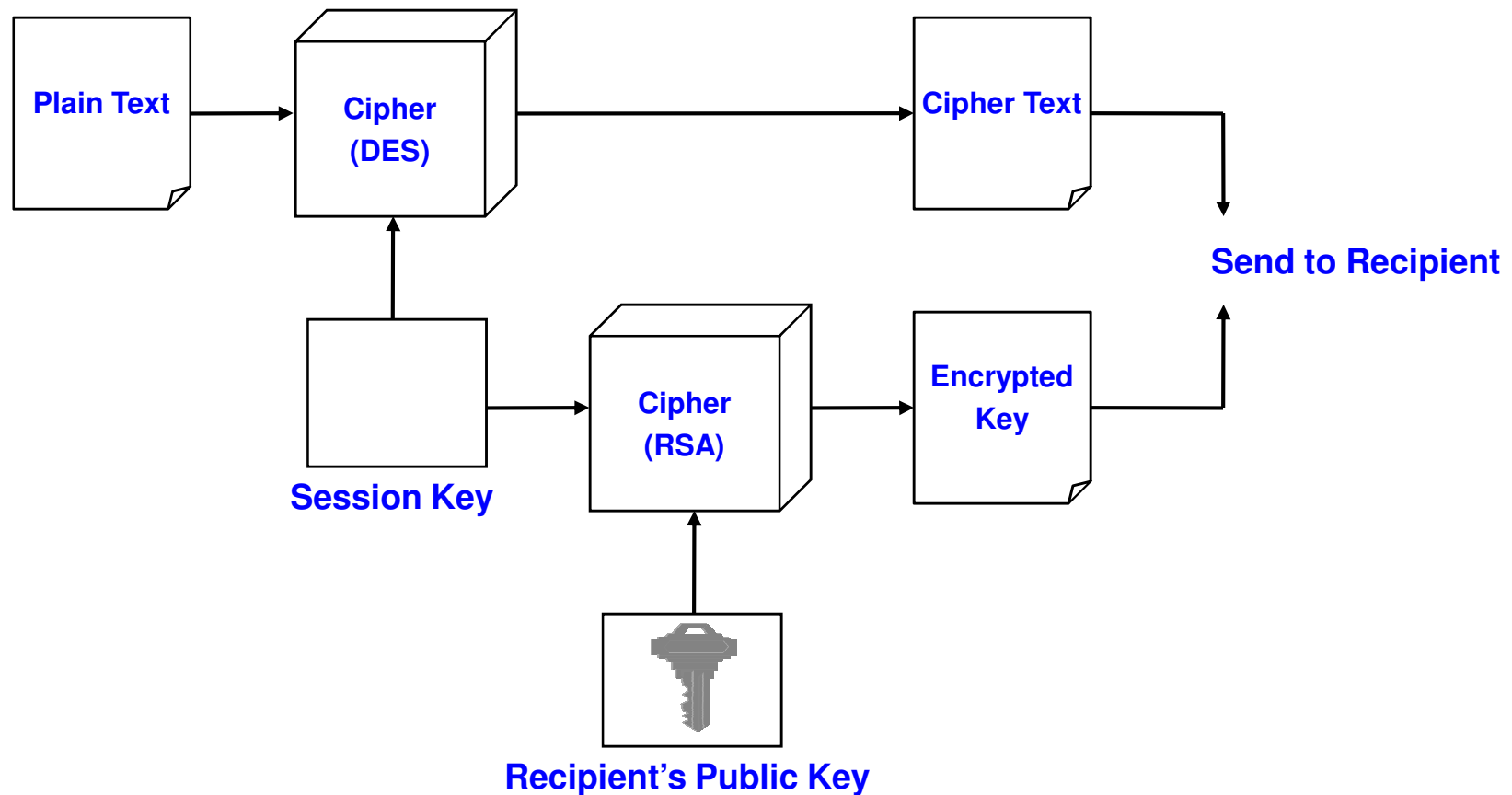
Asymmetric Encryption - Weaknesses

- Slow compared to symmetric Encryption
- It is problematic to get the key pair generated for the encryption.
- Vulnerable to man-in-the-middle attack
 - Hacker could generate a key pair, give the public key away and tell everybody, that it belongs to somebody else. Now, everyone believing it will use this key for encryption, resulting in the hacker being able to read the messages. If he encrypts the messages again with the public key of the real recipient, he will not be recognized easily.



Asymmetric Encryption – Session-Key Encryption

- Used to improve efficiency
 - Symmetric key is used for encrypting data
 - Asymmetric key is used for encrypting the symmetric key

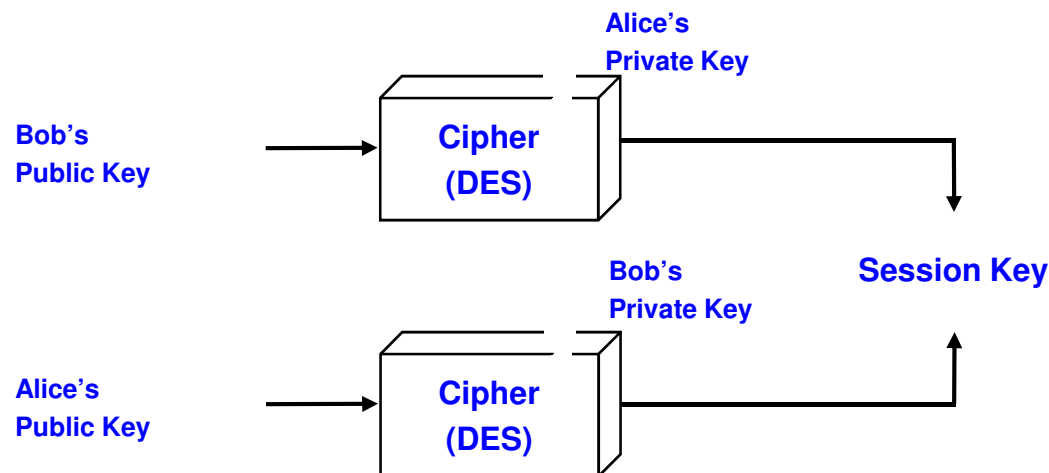


Asymmetric Encryption – Encryption Protocols

- Pretty Good Privacy (PGP)
 - Used to encrypt e-mail using session key encryption
 - Combines RSA, TripleDES, and other algorithms
- Secure/Multipurpose Internet Mail Extension (S/MIME)
 - Newer algorithm for securing e-mail
 - Backed by Microsoft, RSA, AOL
- Secure Socket Layer(SSL) and Transport Layer Socket(TLS)
 - Used for securing TCP/IP Traffic
 - Mainly designed for web use
 - Can be used for any kind of internet traffic

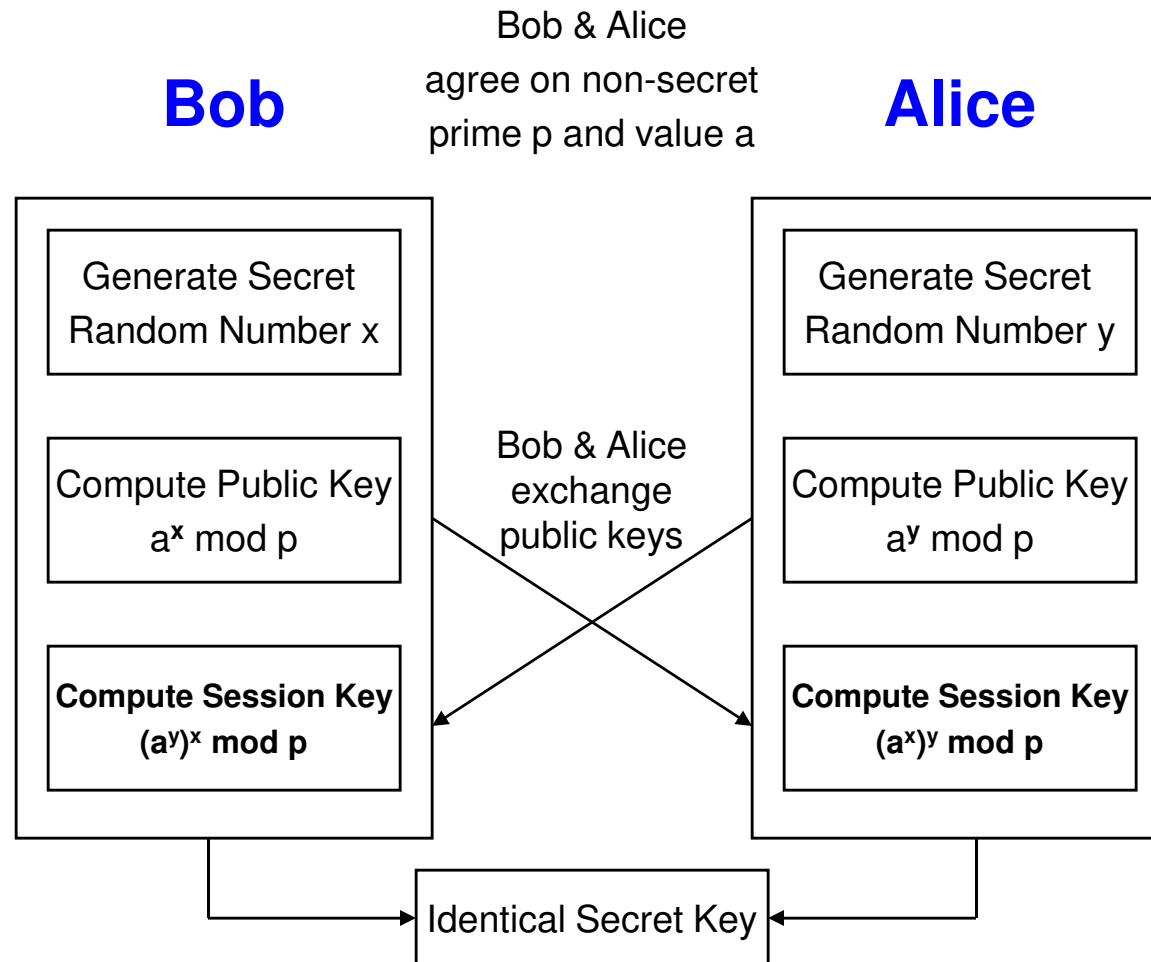
Asymmetric Encryption – Key Agreement

- Key agreement is a method to create secret key by exchanging only public keys.
- Example
 - Bob sends Alice his public key
 - Alice sends Bob her public key
 - Bob uses Alice's public key and his private key to generate a session key
 - Alice uses Bob's public key and her private key to generate a session key
 - Using a key agreement algorithm both will generate same key
 - Bob and Alice do not need to transfer any key



**Alice and Bob
Generate Same
Session Key!**

Diffie-Hellman Mathematical Analysis



Asymmetric Encryption – Key Agreement contd.

- Diffie-Hellman is the first key agreement algorithm
 - Invented by Whitfield Diffie & Martin Hellman
 - Provided ability for messages to be exchanged securely without having to have shared some secret information previously
 - Inception of public key cryptography which allowed keys to be exchanged in the open
- No exchange of secret keys
 - Man-in-the middle attack avoided

Authentication

- Authentication is the process of determining the authenticity of a message or user.
- Two types of authentication:
 - Authentication of the identity presented by a remote or application participating in a session
 - Authentication of the sender's identity is presented along with a message.

Authentication – Password Based

- Use of secret character string only known to user and server
- Problems with password based authentication:
 - Attacker learns password by social engineering
 - Attacker cracks password by brute-force and/or guesswork
 - Eavesdrops password if it is communicated unprotected over the network
 - Replays an encrypted password back to the authentication server

Authentication Protocols

- Set of rules that governs the communication of data related to authentication between the server and the user
- Techniques used to build a protocol are
 - Transformed password
 - Password transformed using one way function before transmission
 - Prevents eavesdropping but not replay
 - Challenge-response
 - Server sends a random value (challenge) to the client along with the authentication request. This must be included in the response
 - Protects against replay
 - Time Stamp
 - The authentication from the client to server must have time-stamp embedded
 - Server checks if the time is reasonable
 - Protects against replay
 - Depends on synchronization of clocks on computers
 - One-time password
 - New password obtained by passing user-password through one-way function n times which keeps incrementing
 - Protects against replay as well as eavesdropping

Authentication Protocols – Kerberos

- Kerberos is an authentication service that uses symmetric key encryption and a key distribution center.
- Kerberos Authentication server contains symmetric keys of all users and also contains information on which user has access privilege to which services on the network

Authentication – Kerberos

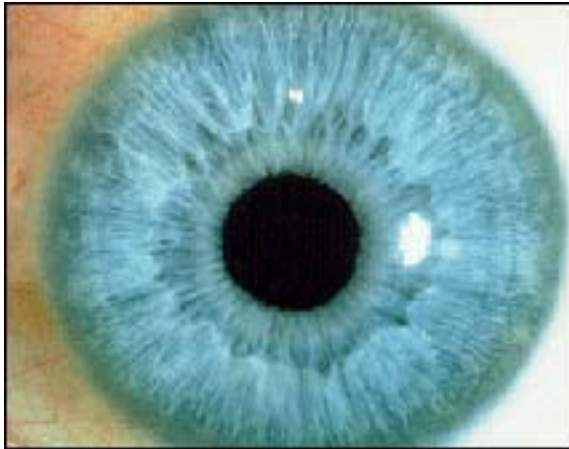
Authentication – Personal Tokens

- Personal Tokens are hardware devices that generate unique strings that are usually used in conjunction with passwords for authentication
- Different types of tokens exist
 - Storage Token: A secret value that is stored on a token and is available after the token has been unlocked using a PIN
 - Synchronous one-time password generator: Generate a new password periodically (e.g. each minute) based on time and a secret code stored in the token
 - Challenge-response: Token computes a number based on a challenge value sent by the server
 - Digital Signature Token: Contains the digital signature private key and computes a digital signature on a supplied data value
- A variety of different physical forms of tokens exist
 - e.g. hand-held devices, Smart Cards, PCMCIA cards, USB tokens

Authentication – Biometrics

- Uses certain biological characteristics for authentication
 - Biometric reader measures physiological indicia and compares them to specified values
 - It is not capable of securing information over the network
- Different techniques exist
 - Fingerprint Recognition
 - Voice Recognition
 - Handwriting Recognition
 - Face Recognition
 - Retinal Scan
 - Hand Geometry Recognition

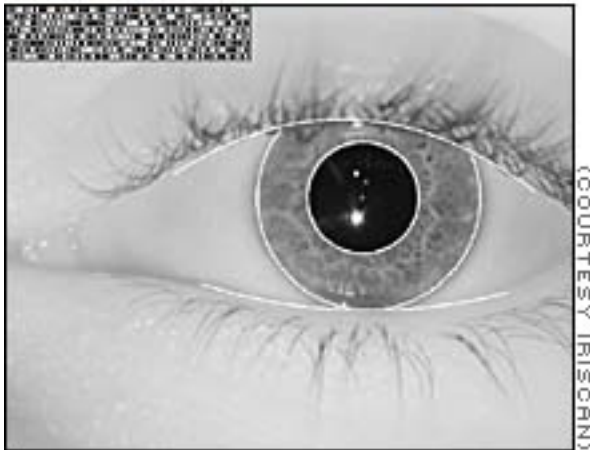
Authentication – Iris Recognition



The scanning process takes advantage of the natural patterns in people's irises, digitizing them for identification purposes

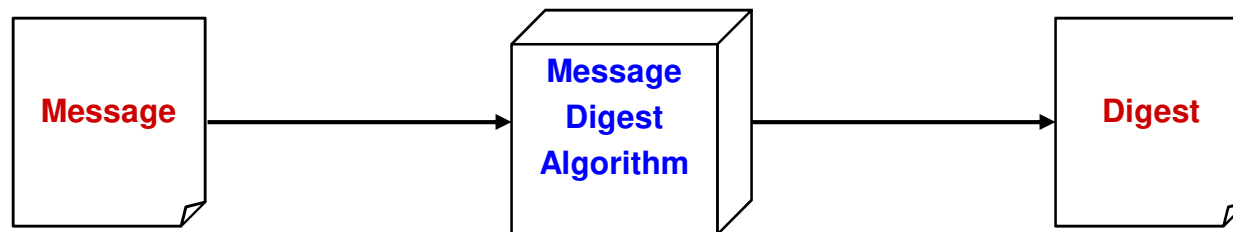
Facts

- Probability of two irises producing exactly the same code: 1 in 10 to the 78th power
- Independent variables (degrees of freedom) extracted: 266
- IrisCode record size: 512 bytes
- Operating systems compatibility: DOS and Windows (NT/95)
- Average identification speed (database of 100,000 IrisCode records): one to two seconds



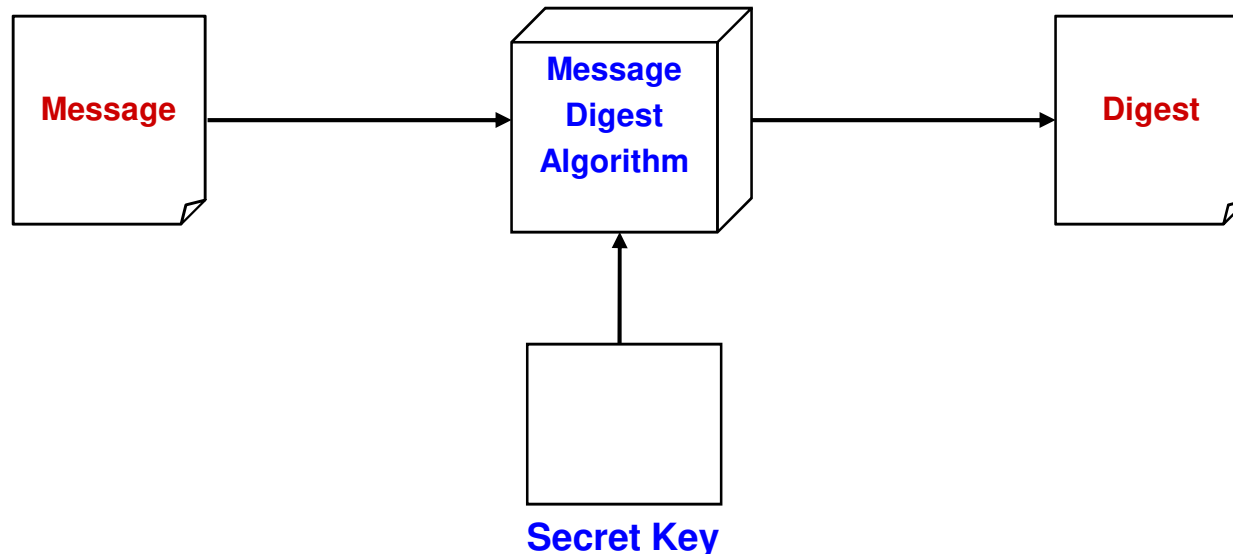
Authentication – Message Digests

- A message digest is a fingerprint for a document
- Purpose of the message digest is to provide proof that a document has not been tampered with.
- Hash functions used to generate message digests are one way functions that have following properties
 - It must be computationally infeasible to reverse the function
 - It must be computationally infeasible to construct two messages which which hash to the same digest
- Some of the commonly used hash algorithms are
 - MD5 - 128 bit hashing algorithm by Ron Rivest of RSA
 - SHA & SHA-1 - 162 bit hashing algorithm developed by NIST



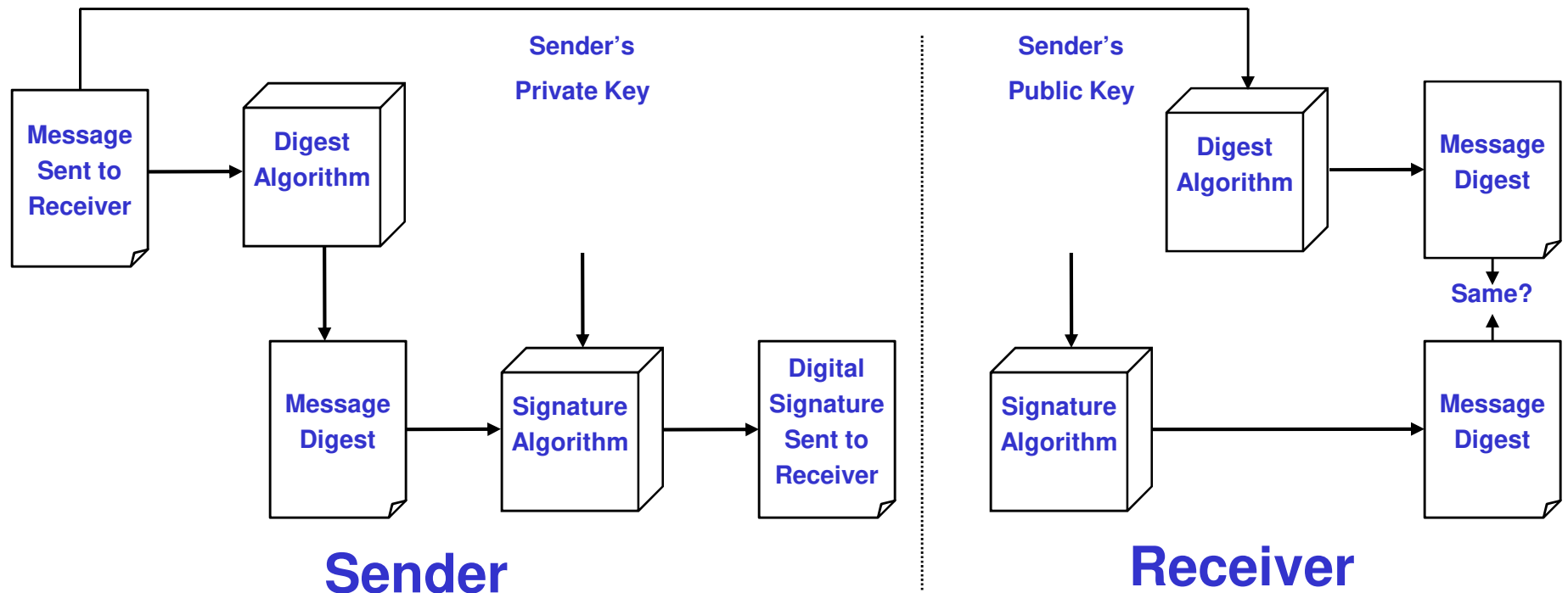
Message Authentication Codes

- A message digest created with a key
- Creates security by requiring a secret key to be possessed by both parties in order to retrieve the message
- Some of the commonly used hash algorithms are
 - MD5 - 128 bit hashing algorithm by Ron Rivest of RSA
 - SHA & SHA-1 - 160 bit hashing algorithm developed by NIST



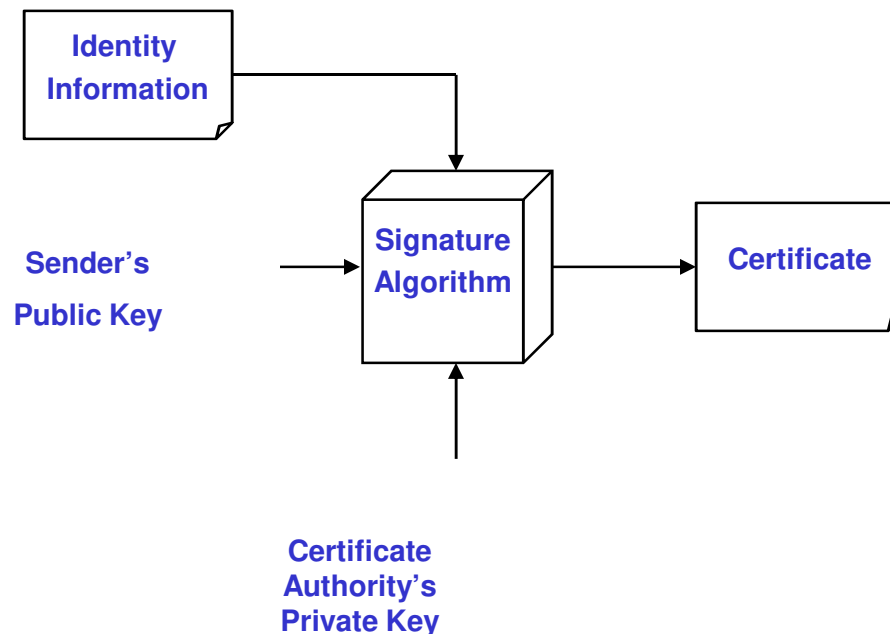
Authentication – Digital Signatures

- A digital signature is a data item which accompanies or is logically associated with a digitally encoded message.
- It has two goals
 - A guarantee of the source of the data
 - Proof that the data has not been tampered with



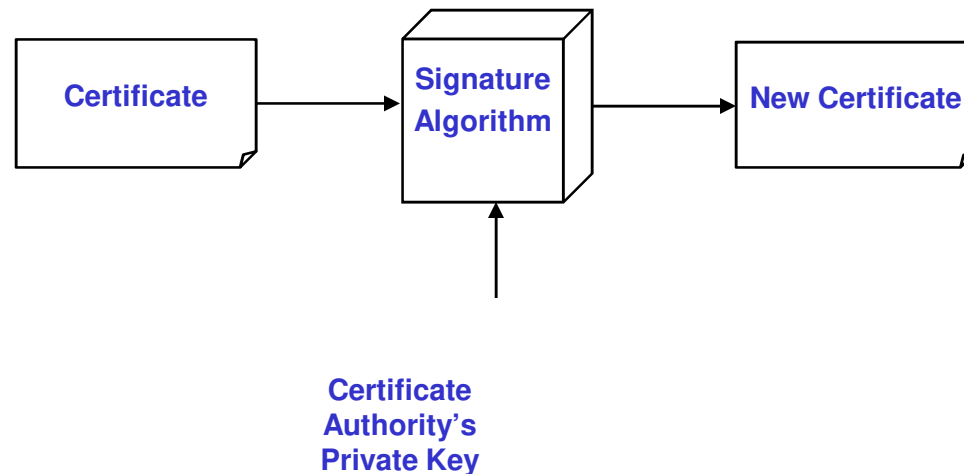
Authentication – Digital Certificates

- A digital certificate is a signed statement by a trusted party that another party's public key belongs to them.
 - This allows one certificate authority to be authorized by a different authority (root CA)
- Top level certificate must be self signed
- Any one can start a certificate authority
 - Name recognition is key to some one recognizing a certificate authority
 - Verisign is industry standard certificate authority



Authentication – Certificate Chaining

- Chaining is the practice of signing a certificate with another private key that has a certificate for its public key
 - Similar to the passport having the seal of the government
- It is essentially a person's public key & some identifying information signed by an authority's private key verifying the person's identity
- The authority's public key can be used to decipher the certificate
- The trusted party is called the certificate authority



Cryptanalysis

- Practice of analyzing and breaking cryptography
- Resistance to crypt analysis is directly proportional to the key size
 - With each extra byte strength of key doubles
- Cracking Pseudo Random Number Generators
 - A lot of the encryption algorithms use PRNGs to generate keys which can also be cracked leading to cracking of algorithms
- Variety of methods for safe guarding keys (Key Management)
 - Encryption & computer access protection
 - Smart Cards